

Отчёт по индивидуальному проекту этап 2

Дисциплина: Основы информационной безопасности

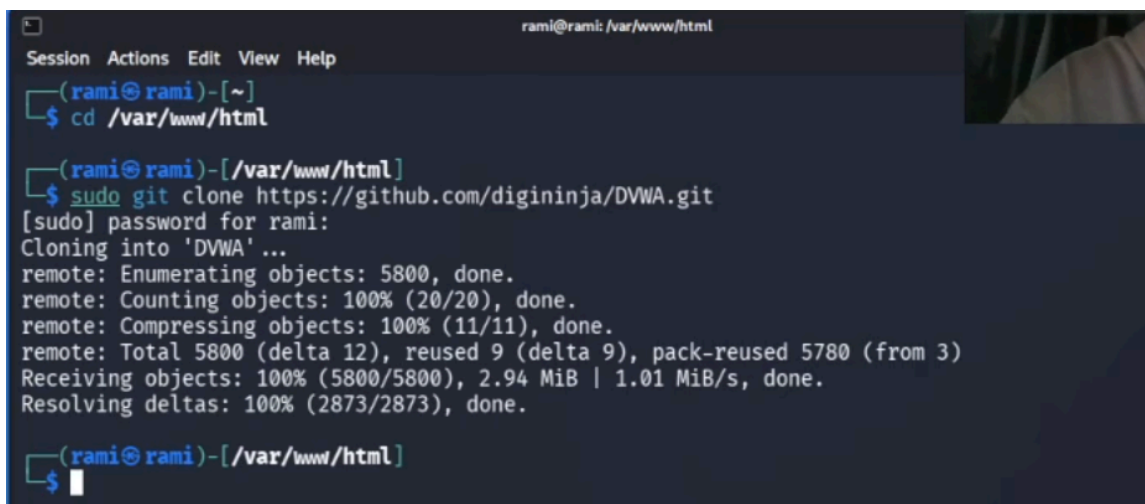
Альманасра Рами
Российский университет дружбы народов
1032235862@rudn.ru

Цель работы

Получить практические навыки по установке DVWA.

Выполнение проекта

Открою терминал, и с помощью `cd`, захожу в директорию `html`, где сохраняются файлы локального хоста. В этой же директории клонирую репозиторий.



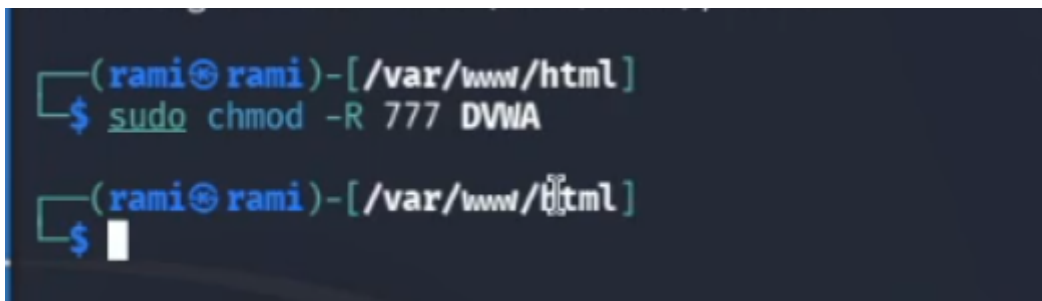
```
rami@rami: /var/www/html
Session Actions Edit View Help
(rami@rami)-[~]
$ cd /var/www/html

(rami@rami)-[/var/www/html]
$ sudo git clone https://github.com/digininja/DVWA.git
[sudo] password for rami:
Cloning into 'DVWA'...
remote: Enumerating objects: 5800, done.
remote: Counting objects: 100% (20/20), done.
remote: Compressing objects: 100% (11/11), done.
remote: Total 5800 (delta 12), reused 9 (delta 9), pack-reused 5780 (from 3)
Receiving objects: 100% (5800/5800), 2.94 MiB | 1.01 MiB/s, done.
Resolving deltas: 100% (2873/2873), done.

(rami@rami)-[/var/www/html]
$
```

Рисунок 1. Клонирование DVWA в /html

Используя `chmod -R 777`, разрешаю все права на все файлы в DVWA



```
(rami@rami)-[/var/www/html]
$ sudo chmod -R 777 DVWA

(rami@rami)-[/var/www/html]
$
```

Рисунок 2. `chmod -R 777`

Далее захожу в dvwa/config, чтобы настроить веб-приложение и копирую config.inc.php который содержит конфигурацию приложения.

A terminal window with a dark background and light blue text. The prompt is (rami@rami)-[/var/www/html]. The first command is \$ cd DVWA/config, which moves the user into the DVWA/config directory. The second command is \$ cp config.inc.php.dist config.inc.php, which copies the distribution file to the final configuration file. The third command is \$, which is the prompt after the second command has executed, with a cursor visible after the dollar sign.

```
(rami@rami)-[/var/www/html]
$ cd DVWA/config

(rami@rami)-[/var/www/html/DVWA/config]
$ cp config.inc.php.dist config.inc.php

(rami@rami)-[/var/www/html/DVWA/config]
$
```

Рисунок 3. копирование config.inc.php

В этом файле изменяю пароль, имя пользователя на rami и сохраняю изменения.

```
GNU nano 9.0                                config.inc.php
<?php

# If you are having problems connecting to the MySQL database and all of the variables below are c>
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to socket>
# Thanks to @digininja for the fix.

# Database management system to use
$DBMS = getenv('DBMS') ?: 'MySQL';
#$DBMS = 'PGSQL'; // Currently disabled

# Database variables
# WARNING: The database specified under db_database WILL BE ENTIRELY DELETED during setup.
# Please use a database dedicated to DVWA.
#
# If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA user.
# See README.md for more information on this.
$_DVWA = array();
$_DVWA[ 'db_server' ] = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA[ 'db_database' ] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA[ 'db_user' ] = getenv('DB_USER') ?: 'rami';
$_DVWA[ 'db_password' ] = getenv('DB_PASSWORD') ?: 'rami99';
$_DVWA[ 'db_port' ] = getenv('DB_PORT') ?: '3306';

# ReCAPTCHA settings
# Used for the 'Insecure CAPTCHA' module
# You'll need to generate your own keys at: https://www.google.com/recaptcha/admin
$_DVWA[ 'recaptcha_public_key' ] = getenv('RECAPTCHA_PUBLIC_KEY') ?: '';
$_DVWA[ 'recaptcha_private_key' ] = getenv('RECAPTCHA_PRIVATE_KEY') ?: '';

# Default security level
# Default value for the security level with each session.
# The default is 'impossible'. You may wish to set this to either 'low', 'medium', 'high' or imp>
$_DVWA[ 'default_security_level' ] = getenv('DEFAULT_SECURITY_LEVEL') ?: 'impossible';

# Default locale
# Default locale for the help page shown with each session.
# The default is 'en'. You may wish to set this to either 'en' or 'zh'.
$_DVWA[ 'default_locale' ] = getenv('DEFAULT_LOCALE') ?: 'en';

# Disable authentication
# Some tools don't like working with authentication and passing cookies around
# so this setting lets you turn off authentication.

Wrote 56 lines

^G Help      ^O Write Out  ^F Where Is   ^K Cut        ^T Execute    ^C Location
^X Exit      ^R Read File  ^\ Replace    ^U Paste      ^J Justify    ^_ Go To Line
```

Рисунок 4. редактирование файла конфигурации

Устанавливаю обновление и mariadb

```
(rami@rami)-[/var/www/html/DVWA/config]
$ sudo apt-get update
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.4 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.3 MB]
Get:4 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [16.0 kB]
Get:5 http://kali.download/kali kali-rolling/non-free-firmware amd64 Contents (deb) [40.6 kB]
Fetched 74.9 MB in 6s (12.8 MB/s)
Reading package lists... Done

(rami@rami)-[/var/www/html/DVWA/config]
$ sudo apt-get -y install apache2 mariadb-server php php-mysqli php-gh libapache2-mod-php
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
Note, selecting 'php8.4-mysql' instead of 'php-mysqli'
E: Unable to locate package php-gh
```

Рисунок 5. Установка mariadb

Запускаю mysql с помощью start mysql.

```
(rami@rami)-[/var/www/html/DVWA/config]
$ sudo service mysql start
```

Рисунок 6. Запуск mysql

Далее я захожу в mysql используя mysql -u root -p

```
(rami@rami)-[/var/www/html/DVWA/config]
$ sudo mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.8.6-MariaDB-6 from Debian -- Please help get to 10k stars at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> █
```

Рисунок 7. mysql

Создаю нового пользователя используя create user „rami“@„127.0.0.1“ identified by „rami99“. Используя эту команду, создал пользователя rami, работающего на сервер локального хоста (127.0.0.1) и пароль rami99.

```
MariaDB [(none)]> create user 'rami'@'127.0.0.1' identified by 'rami99';
Query OK, 0 rows affected (0.012 sec)

MariaDB [(none)]> █
```

Рисунок 8. создание пользоателя

Разрешаю все права доступа этому пользователю к базе данных и завершаю работы.

```
MariaDB [(none)]> grant all privileges on dvwa.* to 'rami'@'127.0.0.1' identified by 'rami99';
Query OK, 0 rows affected (0.010 sec)
```

Рисунок 9. Разрешение права

Далее захожу в /etc/php/8.4. и включаю значения allow_url_fopen и allow_url_include в файле apache2/php.ini.

```
MariaDB [(none)]> grant all privileges on dvwa.* to 'rami'@'127.0.0.1' identified by 'rami99';
Query OK, 0 rows affected (0.010 sec)

MariaDB [(none)]> cd /etc/php/8.4/apache2/
→
→ cd /etc/php/7.3/apache2/
→ exit
→ grant all privileges on dvwa.* to 'rami'@'127.0.0.1' identified by 'rami99';
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that
MariaDB server version 10.5.16
cd /etc/php/7.3/apache2/
exit
grant all privileges on dvwa.* to 'rami'@'127.0.0.1' identified by 'rami99';
MariaDB [(none)]> exit
Bye

(rami@rami)-[/var/www/html]
$ cd /etc/php/7.3/apache2/
cd: no such file or directory

(rami@rami)-[/var/www/html]
$ cd /etc/php/8.4/apache2/
cd: no such file or directory

(rami@rami)-[/etc/php/8.4/apache2]
$ sudo mousepad php.ini
```

*etc/php/8.4/apache2/php.ini - Mousepad

File Edit Search View Document Help

Warning: you are using the root account. You may harm your system.

```
851 upload_max_filesize = 2M
852
853 ; Maximum number of files that can be uploaded via a single request
854 max_file_uploads = 20
855
856 ;;;;;;;;;;;;;;;;;;;;;;;;;
857 ; Fopen wrappers ;
858 ;;;;;;;;;;;;;;;;;;;;;;;;;
859
860 ; Whether to allow the treatment of URLs (like http:// or ftp://) as
861 ; files.
862 ; https://php.net/allow-url-fopen
863 allow_url_fopen = On
864
865 ; Whether to allow include/require to open URLs (like https:// or ftp://)
866 ; as files.
867 ; https://php.net/allow-url-include
868 allow_url_include = On
```

(org.xfce.mousepad:14974): Gtk-WARNING **: 14:25:32.216: Negative content width -13 (allocation 1, extents 7x7) while allocating gadget (node button, owner GtkToggleButton)

(org.xfce.mousepad:14974): Gtk-WARNING **: 14:25:32.216: Negative content height -5 (allocation 1, extents 3x3) while allocating gadget (node button, owner GtkToggleButton)

Рисунок 10. Включение allow_url

Запускаю сервер apache2 используя service apache2 start.

```
(rami@rami)-[/etc/php/8.4/apache2]
$ sudo service apache2 start

(rami@rami)-[/etc/php/8.4/apache2]
$
```

Рисунок 11. запуск apache2

Открою 127.0.0.1./dvwa/setup.php в браузере.

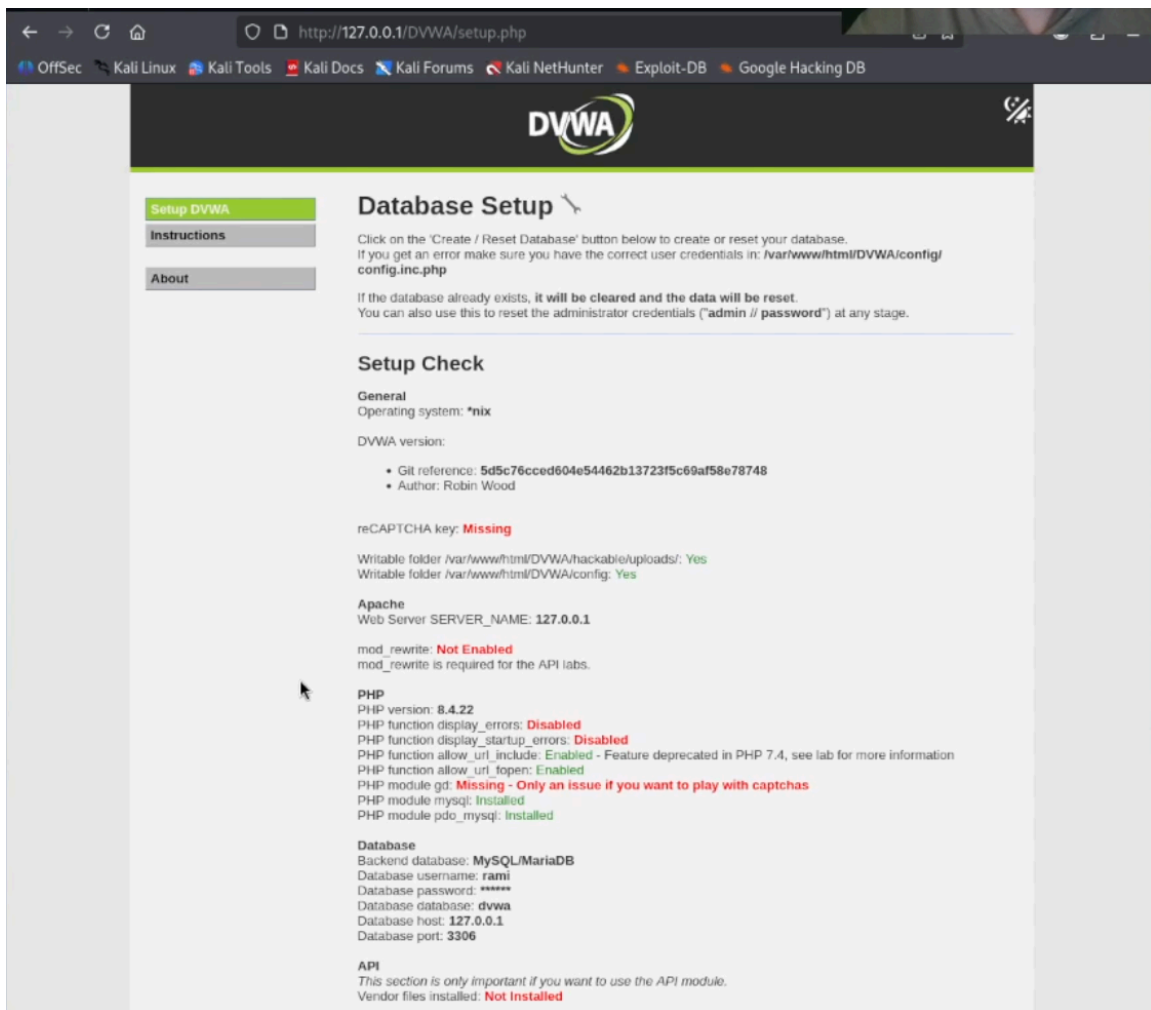


Рисунок 12. страница веб-приложения

Нажимаю кнопку create/Reset database. Создается базу данных и мне перенаправляют на страницу входа. Вхожу используя логин admin и пароль password.



The image shows the login page of the DVWA (Damn Vulnerable Web Application). At the top center is the DVWA logo, which consists of the letters "DVWA" in a bold, black, sans-serif font, with a green and black circular graphic element to its right. Below the logo, there are two input fields. The first is labeled "Username" and contains the text "admin". The second is labeled "Password" and contains a series of dots representing a masked password. Below these fields is a "Login" button. At the bottom center of the page, there is a small link that reads "Damn Vulnerable Web Application (DVWA)".

DVWA

Username
admin

Password
••••••••

Login

[Damn Vulnerable Web Application \(DVWA\)](#)

Рисунок 13. Вход в DVWA

После входа попадаем на домашнюю страницу dvwa.

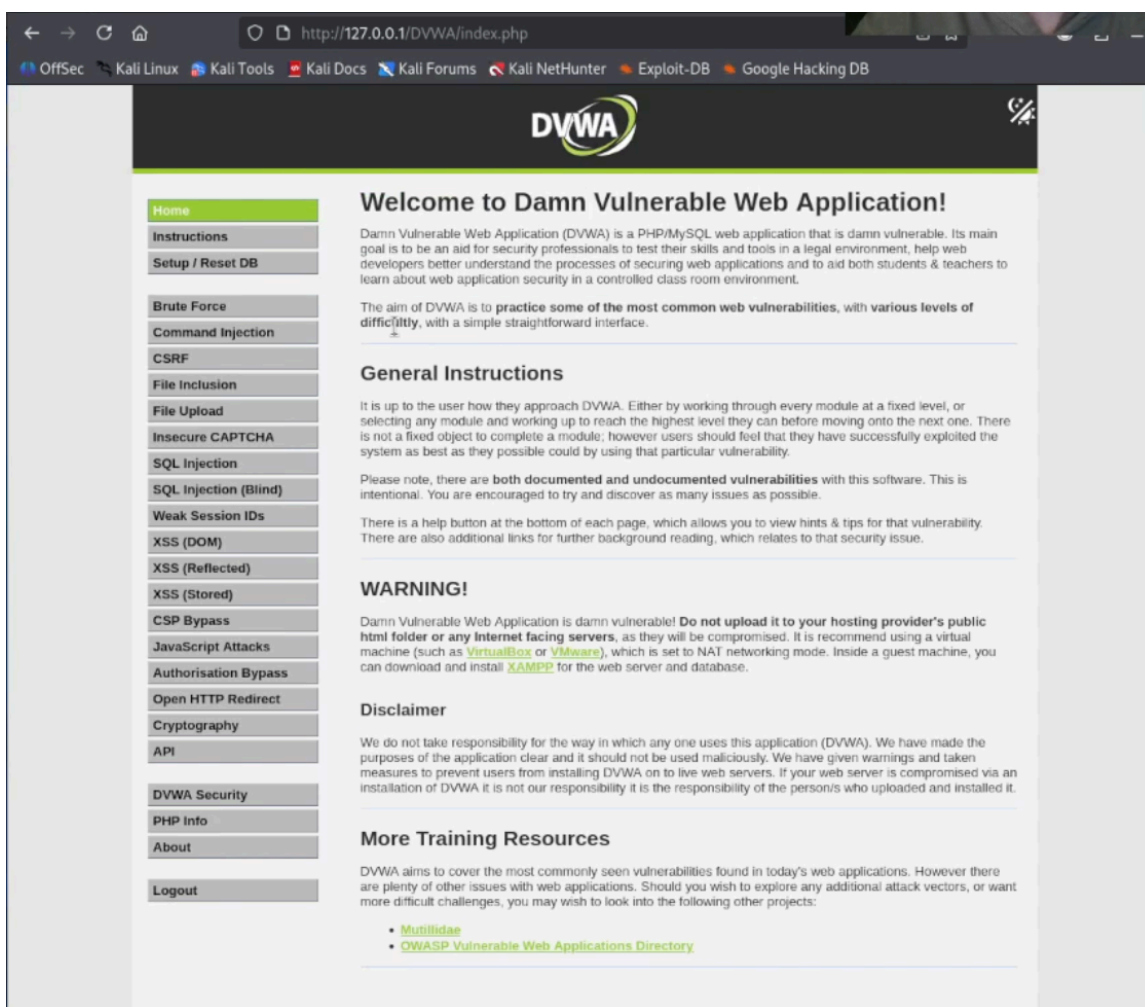


Рисунок 14. Домшняя страница dvwa

Выводы

Получил навыков по установке DVWA.

Список литературы

<https://esystem.rudn.ru/mod/page/view.php?id=1357901> <https://spy-soft.net/dvwa-kali-linux/>